

Data Privacy & Compliance Policy

Personal Data Protection Framework — PDPD, GDPR, and PDPA Compliance

Legal & Compliance Department

Document ID: TVSC-LEG-002 | Version 1.4 | Effective January 1, 2026

1. Scope and Legal Framework

This policy applies to all TechViet employees, contractors, and third-party partners who process, store, or transmit personal data on behalf of TechViet or its clients. TechViet operates under multiple data protection regulations depending on the data subjects and jurisdictions involved:

Regulation	Jurisdiction	Applies When	Key Requirements	Penalty for Non-Compliance
PDPD (Decree 13/2023/ND-CP)	Vietnam	Processing personal data of individuals in Vietnam	Consent, data localization, breach notification within 72 hours, Data Protection Officer required	Up to VND 100M per violation; potential criminal liability
GDPR (Regulation 2016/679)	European Union	Processing data of EU residents (applies to 3 TechViet clients)	Lawful basis, DPIA, DPO, 72-hour breach notification, right to erasure, data portability	Up to €20M or 4% of global annual turnover
PDPA (Act 26 of 2012)	Singapore	Processing data via TechViet's Singapore operations and SG-based clients	Consent, purpose limitation, access and correction rights, 3-day breach notification	Up to SGD 1M per violation

TechViet's Data Protection Officer (DPO) is Tran Thi Kim Anh (dpo@techviet.vn). The DPO reports directly to the CEO and has independent authority to escalate data protection concerns. All employees must complete annual data privacy training (1.5 hours, via LMS) and pass with ≥85%.

2. Data Processing Principles

Principle	Description	How We Implement It
Lawfulness & Fairness	Process personal data only with a valid legal basis (consent, contract, legal obligation, or legitimate interest)	Legal review for all new data processing activities. Consent management system for marketing. Legitimate interest assessments documented.
Purpose Limitation	Collect data only for specified, explicit purposes. Do not use for incompatible purposes.	Privacy notices specify all purposes. Data inventory tracks purpose per dataset. New uses require DPO review.
Data Minimization	Collect only the personal data that is necessary for the stated purpose	Data fields reviewed during system design (Privacy by Design checklist). 'Nice to have' fields rejected by DPO.
Accuracy	Keep personal data accurate and up to date	Self-service update portal for employees and users. Annual data quality audit. Automated address verification for client data.
Storage Limitation	Retain data only as long as necessary for the purpose (see Retention Schedule)	Automated deletion workflows. Retention schedule per data type (Section 4). Annual retention audit by Legal.
Integrity & Confidentiality	Protect data with appropriate technical and organizational security measures	Encryption at rest and in transit. Access controls per IT Security Policy. Regular penetration testing.

Principle	Description	How We Implement It
Accountability	Be able to demonstrate compliance with all principles	Data Protection Impact Assessments (DPIA) for high-risk processing. Processing records maintained. Annual external audit.

3. Personal Data Categories and Handling

Category	Examples	Sensitivity	Storage Requirements	Access Control
Basic Identity	Full name, email, phone, address, date of birth	Standard	Encrypted at rest (AES-256); standard backup procedures	HR team + direct manager for employees; authorized staff for clients
Employment Data	Employee ID, job title, salary, performance reviews, disciplinary records	High	Encrypted + separate database schema; enhanced audit logging	HR team only; manager sees only own reports; employee sees own data
Financial Data	Bank accounts, tax IDs, payment card numbers, salary history	High	PCI DSS Level 1 compliant storage; tokenization for card data; separate encryption keys	Finance team only; tokenized for all other systems; PCI-scoped access
Health Data	Insurance claims, medical certificates, disability status, COVID vaccination	Sensitive	Physically separate encrypted database; own encryption keys; no cloud replication	HR health admin (1 person) + DPO; manager sees only leave dates, not medical details
Biometric Data	Fingerprint (office access), facial recognition (visitor management)	Sensitive	On-premises processing and storage ONLY; templates stored, not raw biometrics; no cloud	Security team only; 30-day auto-deletion; cannot be exported
Client End-User PII	Data processed on behalf of clients (varies per contract)	Variable (per DPA)	Per client Data Processing Agreement; data segregation mandatory; client-specific encryption	Project team only (scoped); access revoked at project end; no cross-project access

4. Data Retention Schedule

Data Type	Retention Period	Action After Retention	Legal Basis	Automated?
Employee records (active)	Duration of employment	Move to archive upon separation	Employment contract	N/A
Employee records (separated)	5 years after separation	Anonymize (aggregated for analytics) or delete	Vietnamese Labor Code + tax law	Annual review; batch process in January
Client project data	Contract duration + 3 years	Delete per client DPA terms; certificate of destruction	Contractual obligation	Automated reminder at contract end + 2.5 years
Financial / accounting records	10 years from creation	Move to read-only archive for 2 additional years, then delete	Vietnamese tax regulations (Decree 123/2020)	Automated archival; manual deletion
Application / system logs	90 days	Auto-deleted from all systems including backups	Legitimate interest (security monitoring)	Fully automated (Datadog log pipeline)
Security camera footage	30 days	Auto-overwritten by recording system	Legitimate interest (physical security)	Hardware-level auto-overwrite

Data Type	Retention Period	Action After Retention	Legal Basis	Automated?
Email communications	3 years active + 2 years archive	Permanent deletion from all backups	Business operations	Google Workspace retention policy + Veeam
Marketing consent records	Duration of consent + 2 years	Delete consent record and all associated data	PDPD Article 11 + GDPR Article 7	Consent management system auto-tracks
Job applicant data (not hired)	6 months after hiring decision	Delete unless candidate consents to talent pool retention (max 2 years)	Consent (talent pool) / Legitimate interest (rejected)	Automated via ATS (Greenhouse) pipeline
Website analytics / cookies	26 months from collection	Auto-deleted from analytics platform	Consent (cookie banner)	Google Analytics 4 auto-deletion setting

5. Data Subject Rights

TechViet respects and facilitates the rights of all data subjects under applicable privacy laws. Requests can be submitted via the Privacy Portal (privacy.techviet.vn), email (privacy@techviet.vn), or in writing to the DPO. All requests are logged, tracked, and must be responded to within the deadlines specified below.

Right	Description	Response Time	Process	Exceptions
Right of Access	Obtain a complete copy of all personal data we hold about you, in a readable format	30 days (PDPD/GDPR); 21 days (PDPA)	Submit request via Privacy Portal. Identity verification required. Data compiled by DPO office.	May be restricted if disclosure would compromise security investigation or legal proceedings
Right to Rectification	Correct or update inaccurate or incomplete personal data	15 days	Self-service via HR Portal (employees) or Privacy Portal (others). Complex changes reviewed by DPO.	None — always honored
Right to Erasure	Request deletion of personal data when no longer necessary or consent withdrawn	30 days	DPO reviews request against retention obligations. If approved, deletion across all systems + backups.	Cannot override legal retention requirements (tax, labor law). Will explain which data and why.
Right to Data Portability	Receive your data in a structured, machine-readable format (JSON/CSV)	30 days	Export generated by automated system. Delivered via secure download link (encrypted, 7-day expiry).	Applies only to data provided by the subject, not derived/inferred data
Right to Restrict Processing	Pause processing of your data while a dispute or objection is being resolved	15 days to implement restriction	DPO implements technical restriction. Data retained but not processed until resolved.	Essential processing (legal obligations, contract performance) may continue
Right to Object	Object to processing based on legitimate interest grounds	30 days for response	DPO conducts balancing test: individual rights vs. TechViet legitimate interest. Decision documented.	Cannot object to processing required by law or contract
Right to Withdraw Consent	Withdraw any previously given consent at any time, without affecting past processing	Immediate effect	Self-service via consent management (for marketing). Privacy Portal for other consent-based processing.	Withdrawal does not affect lawfulness of prior processing based on consent

6. Data Breach Response Procedure

Phase	Actions	Timeline	Responsible	Documentation
1. Detection & Containment	Identify breach vector. Isolate affected systems. Preserve forensic evidence. Stop ongoing data loss.	Immediate upon discovery. Must be reported to SOC within 1 hour.	SOC / IT Security (first responder); CISO (escalation)	Incident ticket in Jira; real-time updates in Slack incident channel
2. Assessment	Determine: scope (how many records), type (what data), root cause, affected individuals, ongoing risk.	Within 4 hours of detection	DPO + CISO + affected team leads	Breach assessment report (template in Confluence)
3. Internal Notification	Brief CEO, Legal, affected department heads. Prepare external notification if required.	Within 8 hours	DPO	Internal briefing document

Phase	Actions	Timeline	Responsible	Documentation
4. Authority Notification	Report to relevant data protection authority if required (mandatory for breaches affecting >1000 individuals or sensitive data).	Within 72 hours (PDPD /GDPR); 3 days (PDPA)	DPO + Legal Counsel	Authority notification form (per regulation)
5. Individual Notification	Notify affected data subjects if breach poses high risk to their rights. Include: what happened, what data, what we're doing, what they should do.	Without undue delay after authority notification	DPO + Communications team	Notification letter/email (Legal-reviewed template)
6. Remediation	Implement technical and organizational fixes. Patch vulnerabilities. Update access controls.	Per remediation action plan (typically 1-4 weeks)	IT Security + Engineering	Remediation plan with deadlines; tracked in Jira
7. Post-Incident Review	Document lessons learned. Update policies and procedures. Conduct additional training if needed.	Within 14 days of incident closure	DPO + CISO + all involved parties	Post-incident report (published to Legal & Security teams)